

MODULE 26 · DOMAIN 3 - CONTINUOUS IMPROVEMENT FOR EXISTING SOLUTIONS

Systems Manager Operations

Turning "log into the server" into an API call that leaves a record.

DOMAIN 3 of 4 EXAM WEIGHT 25% MODULE 26 of 44

If administration is an API call, it inherits **IAM, CloudTrail and automation**. If it is an SSH session, it inherits none of them.

Session Manager

- ◆ **Shell access with no inbound ports, no bastion host and no SSH keys.** The agent connects outbound to Systems Manager.
- ◆ **Every session is logged** to S3 or CloudWatch Logs, and can be recorded keystroke by keystroke.
- ◆ **Port forwarding** tunnels to a database or a web console without opening anything to the internet.
- ◆ Access is governed by IAM, so permissions can be scoped by instance tag rather than by network position.

ON THE EXAM

This is why bastion hosts are an anti-pattern now. A bastion is a server to patch, protect and audit that provides no capability Session Manager lacks.

Just-in-time node access

- ◆ **Zero standing privileges.** Operators request access to a node, rather than holding it permanently.
- ◆ **Approval policies decide: deny, auto-approve, or require a human.** Written in Cedar, with timeouts and session limits.
- ◆ Covers EC2, on-premises and multi-cloud nodes, and adds **RDP session recording** to S3.
- ◆ Enabling it changes nothing until you **remove ssm:StartSession** from your IAM policies. Both paths coexist until then.

ON THE EXAM

Session Manager removes the bastion. Just-in-time node access removes the standing permission that replaced it.

What a managed node needs

- ◆ **The SSM Agent installed and running**, plus outbound connectivity to the Systems Manager endpoints.
- ◆ **An instance profile** granting the managed instance permissions, or Default Host Management Configuration doing it for you.
- ◆ In a private subnet with no NAT, you need **interface endpoints** for ssm, ssmmessages and ec2messages.
- ◆ An instance missing from Fleet Manager is almost always one of those three. Agent, role, or network path.

ON THE EXAM

Three endpoints, not one. Missing ssmmessages is the classic cause of an instance that registers but cannot start a session.

Patch Manager

- ◆ A **patch baseline** defines which patches are approved, with auto-approval rules and an approval delay for testing.
- ◆ **Patch groups** are just a tag, letting you patch development a week before production with the same baseline.
- ◆ **Maintenance windows** control when. **Patch policies** configure scanning and patching across an organisation from one place.
- ◆ Scan-only mode reports compliance without installing anything, which is how you start.

ON THE EXAM

Patch compliance is reported into Systems Manager and Config, so it becomes evidence rather than an assertion.

Which Systems Manager tool?

YOU WANT TO	USE	BECAUSE
Run a command now, on many nodes	Run Command	One-off, targeted by tag or resource group
Keep configuration as you defined it	State Manager	Associations reapply on a schedule
Fix something with steps and branching	Automation	Runbooks handle multi-step workflows
Know what software is installed	Inventory	Collects applications, patches, network config
Patch a fleet on a schedule	Patch Manager	Baselines, groups and maintenance windows

ON THE EXAM

Run Command is now, once. State Manager is continuously, forever. That is the distinction the exam tests most.

Beyond AWS

- ◆ **Hybrid activations** register on-premises servers, virtual machines and other clouds as managed nodes.
- ◆ They then use the same Session Manager, Run Command, Patch Manager and Inventory as EC2 instances.
- ◆ This is often the strongest argument for Systems Manager: one operational model across a hybrid estate.
- ◆ Hybrid nodes beyond the free allowance are billed on the advanced tier, so it is not free at scale.

ON THE EXAM

A company halfway through a migration runs two estates. Systems Manager is one of the few things that treats them identically.

Reading the scenario

THE SCENARIO SAYS

Remove bastion hosts and SSH keys

Nobody should hold standing access to nodes

Patch thousands of instances on a schedule

Configuration keeps drifting back

Run one command across a tagged fleet now

Manage on-premises servers the same way

IT IS POINTING AT

Session Manager

Just-in-time node access

Patch Manager with patch policies

State Manager associations

Run Command

Hybrid activations

ON THE EXAM

Ask whether the need is once or continuous, and whether it is AWS-only or hybrid. Those two answers pick the tool.

Meridian Freight runs four bastion hosts, one per environment, with SSH keys distributed to 60 engineers. Auditors have asked who connected to which server and what they typed, and nobody can answer. Key rotation has not happened in two years.

The bastions themselves must be patched and monitored.

What should the solutions architect recommend?

- A Session Manager, with session logging to CloudWatch Logs, and decommission the bastions
- B Rotate the SSH keys quarterly and enable verbose sshd logging on the bastions
- C Move the bastions into a dedicated account with tighter security groups
- D Replace SSH with RDP for easier auditing

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Session Manager, drop the bastions
Removes the keys, the inbound ports and four servers to maintain, while giving IAM-controlled access and a full session record.
- B

 Rotate keys, more logging
Improves a design that should not exist. Keys still need distributing, and bastion logs are on a host users can reach.
- C

 Bastions in their own account
Relocates the problem. There are still four servers, sixty keys, and no record of what anyone typed.
- D

 RDP instead of SSH
Changes the protocol, not the model. Standing access, distributed credentials and no central audit trail remain.

THE SIGNAL

Three requirements: who connected, what they typed, and no unrotated keys. One service satisfies all three and removes four servers.

A bank has adopted Session Manager successfully. A new security policy now requires zero standing privileges: no engineer should be able to connect to a production node without an explicit, time-bound approval recorded at the moment of access.

Operational efficiency must not suffer for non-production environments.

What should the solutions architect implement?

- A Just-in-time node access, with approval policies requiring human approval for production and auto-approval elsewhere
- B Remove ssm:StartSession from all IAM policies and grant it manually on request
- C A permissions boundary limiting engineers to non-production instances
- D Shorten the Session Manager idle timeout

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

JITNA with per-environment policies
Approval policies can deny, auto-approve or require a human, so production gets approval and non-production stays frictionless.
- B

Manual IAM grants on request
Achieves zero standing privileges by making a human edit IAM policies at 3am. It is JITNA, built badly, with no audit structure.
- C

Permissions boundary
Removes production access entirely rather than gating it. Engineers legitimately need production access sometimes.
- D

Shorter idle timeout
Ends idle sessions sooner. The permission to start a new one at any moment is untouched.

THE SIGNAL

Zero standing privileges plus different rules per environment is exactly what approval policies express. One mechanism, two behaviours.

A company must patch 3,000 instances across 40 accounts monthly. Development should receive patches a week before production. Compliance requires evidence of patch status per instance, and a security team wants to confirm coverage without visiting each account. Patching must occur only within approved maintenance windows.

What should the solutions architect implement?

- ☐ A Patch Manager with a baseline, patch groups by tag, maintenance windows, and patch policies deployed organisation-wide
- ☐ B A Run Command execution issued monthly against all instances
- ☐ C A State Manager association running the patch document hourly
- ☐ D Rebuild instances monthly from a freshly patched AMI

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A** Patch Manager, full arrangement
The baseline's approval delay gives development its week ahead, groups are tags, windows control timing, and compliance data is reported centrally.
- B** Monthly Run Command
A human must remember to run it in 40 accounts, with no maintenance window control and no compliance reporting.
- C** Hourly State Manager
Continuous patching ignores the maintenance window requirement entirely, which is the one constraint stated most firmly.
- D** Rebuild from AMIs
Defensible for immutable stateless fleets, and a very large change proposed to solve a patching problem, with no per-instance evidence.

THE SIGNAL

Four requirements, four Patch Manager concepts. Baseline delay, tag-based groups, maintenance windows, and compliance reporting.

The CloudWatch agent configuration on a fleet keeps reverting. Engineers troubleshooting incidents edit the config locally, then forget to revert. Weeks later, instances are found publishing the wrong metrics, and nobody knows which ones are correct.

The desired configuration is well documented.

What should the solutions architect implement?

- ☐ A A State Manager association applying the desired configuration on a schedule
- ☐ B A Run Command execution applying the configuration once to all instances
- ☐ C Deny engineers shell access to production instances
- ☐ D Rebuild the instances from a corrected AMI

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

 State Manager association
Reapplies the documented configuration on a schedule, so a local edit survives only until the next run. Drift corrects itself.
- B

 Run Command once
Fixes every instance today. The next incident produces the same drift, because nothing reapplies the configuration.
- C

 Deny shell access
Prevents the edits and the troubleshooting. Engineers change the config during incidents for a reason.
- D

 Rebuild from an AMI
A heavy correction that also only holds until the next incident. It has the same weakness as B, more expensively.

THE SIGNAL

The word is keeps. A recurring drift needs something continuous, which is exactly what separates State Manager from Run Command.

Newly launched instances in a private subnet do not appear in Fleet Manager. The AMI includes the SSM Agent and the agent process is running. The instances have an instance profile with the AmazonSSMManagedInstanceCore policy. There is no NAT gateway in the VPC.

Instances in a public subnet with identical configuration register normally.

What is the MOST likely cause?

- ☐ A The private subnet lacks VPC interface endpoints for ssm, ssmmessages and ec2messages
- ☐ B The instance profile needs AdministratorAccess
- ☐ C The SSM Agent version is out of date
- ☐ D Default Host Management Configuration is not enabled

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

Missing interface endpoints
The agent connects outbound to Systems Manager. With no NAT and no endpoints, a private subnet has no path at all.
- B

AdministratorAccess
The managed instance core policy is exactly what AWS provides for this. More permission does not create a network path.
- C

Old agent version
Would likely still register, and the identical AMI works in a public subnet, so the agent is not the variable.
- D

Default Host Management
An alternative way to grant permissions. The instances already have an instance profile, so permissions are covered.

THE SIGNAL

Same AMI, same role, different subnet. When one variable differs, that variable is the answer.

A company is two years into a migration. It runs 1,400 EC2 instances and 900 on-premises servers, and expects to run both for another three years. Patch compliance, software inventory and remote access are handled by different tools in each estate, and auditors receive two incompatible reports.

The security team wants one operational model.

What should the solutions architect recommend?

- ☐ A Register the on-premises servers as managed nodes using hybrid activations
- ☐ B Accelerate the migration so everything runs on EC2
- ☐ C Deploy the third-party on-premises tool into AWS as well
- ☐ D Keep both tools and write a script that merges the two reports

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Hybrid activations
On-premises servers become managed nodes, using the same patch baselines, inventory and Session Manager as EC2. One model, one report.
- B

 Accelerate the migration
The scenario says both estates run for three more years. Changing the business plan is not an architectural answer.
- C

 Third-party tool into AWS
Defensible, and it means running and licensing that tool across a much larger estate, plus losing the AWS-native integrations.
- D

 Merge the reports
Produces one report from two operational models. The auditors are satisfied and the operations teams are not.

THE SIGNAL

Three more years of both estates is the planted constraint. It rules out any answer that depends on the hybrid period ending.

What to carry out of this module

- ◆ **Session Manager removes the bastion.** Just-in-time node access removes the standing permission that replaced it.
- ◆ **Run Command is now, once. State Manager is continuously, forever.** The word keeps in a scenario chooses State Manager.
- ◆ **Three endpoints**, not one: ssm, ssmmessages and ec2messages. Missing the second is the classic silent failure.
- ◆ **Hybrid activations** give one operational model across AWS and on-premises, which matters most mid-migration.

ON THE EXAM

Administration through an API inherits IAM and CloudTrail. Administration over SSH inherits neither, which is the whole argument.